

Sri Lanka Institute of Information Technology



Group 3

Network Security Assignment

Group Details

	Student ID	Student Name	Email
1	IT23662346	Hansaja R.D	it23662346@my.sliit.lk
2	IT23394988	Danamjan V	it23394988@my.sliit.lk
3	IT23611788	Herath H.M.B.D	it23611788@my.sliit.lk
4	IT23642300	Sathursha.R	it23642300@my.sliit.lk

Network Security – IE3032

B.Sc. (Hons) in Information Technology

Specialized in Cybersecurity

Table of Contents

1	Introduction	4
2	Vulnerability 1: CVE-2025-20333 - Cisco ASA and FTD WebVPN Heap Buffer Overflow 5	
2.1	Device or Protocol Affected	5
2.2	Nature of Vulnerability & Severity	5
2.3	Component Affected.....	5
2.4	Reason for the Vulnerability to Exist	6
2.5	Exploitation Methods	6
2.6	Example Attacks.....	6
2.7	Impact of the Attacks.....	7
2.8	Mitigation Strategies.....	7
3	Vulnerability 2: CVE-2024-6387 - OpenSSH "regreSSHion" RCE.....	8
3.1	Protocol Affected.....	8
3.2	Nature of Vulnerability & Severity	8
3.3	Component Affected.....	8
3.4	Reason for the Vulnerability to Exist	8
3.5	Exploitation Methods	9
3.6	Example Attacks.....	9
3.7	Impact of the Attacks.....	9
3.8	Mitigation Strategies.....	9
4	Vulnerability 3: CVE-2023-20198 - Cisco IOS XE Web UI Privilege Escalation / RCE.....	10
4.1	Device or Protocol Affected	10
4.2	Nature of Vulnerability & Severity	10
4.3	Component Affected and Reason for the Vulnerability to Exist	11
4.4	Exploitation Methods and Example Attacks	11
4.5	Impact of the Attacks.....	12
4.6	Mitigation Strategies.....	12
5	Vulnerability 4: CVE-2023-27997 - Fortinet FortiOS / FortiProxy SSL-VPN Heap Overflow ("Xortigate").....	13
5.1	Device or Protocol Affected	13
5.2	Nature of Vulnerability & Severity	13
5.3	Component Affected and Reason for the Vulnerability to Exist	13
5.4	Exploitation Methods and Example Attacks	14
5.5	Impact of the Attacks.....	14
5.6	Mitigation Strategies.....	15
6	Vulnerability 5: CVE-2025-0282 – Ivanti Connect Secure Stack-Based Buffer Overflow..	16
6.1	Device or Protocol Affected	16
6.2	Nature of Vulnerability & Severity	16

6.3	Component Affected.....	16
6.4	Reason for the Vulnerability to Exist	17
6.5	Exploitation Methods	17
6.6	Example Attacks.....	17
6.7	Impact of the Attacks.....	18
6.8	Mitigation Strategies.....	18
7	Vulnerability 6: CVE-2024-3400 – Palo Alto Networks PAN-OS Global Protect Command Injection	19
7.1	Device or Protocol Affected	19
7.2	Nature of Vulnerability & Severity	19
7.3	Component Affected.....	19
7.4	Reason for the Vulnerability to Exist	20
7.5	Exploitation Methods	20
7.6	Example Attacks.....	20
7.7	Impact of the Attacks.....	21
7.8	Mitigation Strategies.....	21
8	Vulnerability 7: CVE-2023-44487 – HTTP/2 Rapid Reset Attack.....	22
8.1	Device or Protocol Affected	22
8.2	Nature of Vulnerability & Severity	22
8.3	Component Affected.....	22
8.4	Reason for the Vulnerability to Exist	22
8.5	Exploitation Methods	23
8.6	Example Attacks.....	23
8.7	Impact of the Attacks.....	23
8.8	Mitigation Strategies.....	23
9	Vulnerability 8: CVE-2023-4966 – Citrix NetScaler “Citrix Bleed”	24
9.1	Device or Protocol Affected	24
9.2	Nature of Vulnerability & Severity	24
9.3	Component Affected.....	24
9.4	Reason for the Vulnerability to Exist	24
9.5	Exploitation Methods	25
9.6	Example Attacks.....	25
9.7	Impact of the Attacks.....	25
9.8	Mitigation Strategies.....	25
10	Conclusion.....	26
11	Contribution	27
12	References	28

1 Introduction

Modern organizations highly rely on networking devices and protocols to achieve the requirements of the organization including communication, remote access and fulfilling business operations. However, these systems have been a direct target for cyberattacks due to increasing complexity and exposure of these systems. Vulnerabilities in network hardware such as switches, firewalls, gateways and servers are the main reason for severe security breaches. As a result of these weaknesses within network assets attackers are allowed to gain unauthorized access, execute malicious codes and cause disruptions in systems.

This report describes eight recent vulnerabilities affected towards common networking devices and protocols, including Cisco ASA/FTD, OpenSSH, Fortinet FortiOS, Ivanti Connect Secure, Palo Alto PAN-OS, HTTP/2, and Citrix NetScaler. This report explains each Identified vulnerability based on the affected device or protocol, nature and severity, impacted components, root causes, exploitation methods, real-world attack scenarios, and the impact on organizations.

Moreover, this report presents mitigation strategies to reduce risks associated with these vulnerabilities. The goal of this report is to provide detailed understanding of how such vulnerabilities are exploited in the real world and how organizations can implement effective countermeasures to strengthen the network infrastructure.

2 Vulnerability 1: CVE-2025-20333 - Cisco ASA and FTD WebVPN Heap Buffer Overflow

Vulnerability	CVE-2025-20333
Affected Entity	Cisco ASA/FTD Software
Severity	Critical
Rating	9.9/10.0
Published Date	09/25/2025

2.1 Device or Protocol Affected

This vulnerability affects the embedded VPN web server operating within two primary Cisco operating systems. **Cisco Secure Firewall Adaptive Security Appliance (ASA) Software** and **Cisco Secure Firewall Threat Defense (FTD) Software** [1], [2].

The vulnerability is not affected by all devices running these operating systems as it specifically targets the HTTP and HTTPS protocols when certain Remote Access VPN features are configured, this activates vulnerable SSL listen sockets on public-facing interfaces [2].

A device is considered Vulnerable if one or more of these features are enabled [2]

- AnyConnect IKEv2 Remote Access
- Mobile User Security (MUS)
- SSL VPN (WebVPN)

2.2 Nature of Vulnerability & Severity

The vulnerability is a heap-based buffer overflow, which is categorized as CWE-120 this allows Buffer Copy without Checking Size of Input. It is classified with a **CRITICAL** severity rating, holding within the maximum **CVSS base score of 9.9 out of 10** [1].

Although the exploitation of this vulnerability needs legitimate VPN credentials, the vulnerability becomes severe in the real world as threat actors actively combine it with missing authorization flaws [3]. This allows threat actors to bypass login requirements entirely, achieving zero-click, unauthenticated RCE that results in a complete system compromise.

2.3 Component Affected

The component affected by this vulnerability is in a **Lua endpoint**, which is embedded within the daemon of the WebVPN server of the Cisco ASA and FTD software [1], [3]. This endpoint is responsible for processing incoming HTTP and HTTPS requests [1], [2]. Furthermore, this file handles uploads for the remote access VPN service. Because the vulnerable component is attached directly to the VPN web server, it exposes public-facing interfaces on the firewall [2].

2.4 Reason for the Vulnerability to Exist

This vulnerability arises from improper validation of user input in HTTP/HTTPS requests combined with the failure of the system to perform required bounds checking within the underlying C/C++ memory allocator while calculating the buffer size required for incoming data. When a specifically crafted payload is received, system copies the input without validation, which results in overflowing the allocated heap buffer and overwriting adjacent memory space [1], [3].

2.5 Exploitation Methods

An attacker exploits this by sending specifically crafted, oversized HTTP requests to the vulnerable WebVPN endpoint [1], [2]. Although this vulnerability requires authentication, attackers actively chain it with path traversal/missing authorization vulnerabilities to bypass login requirements entirely, achieving zero-click, unauthenticated remote code execution as the root user [3].

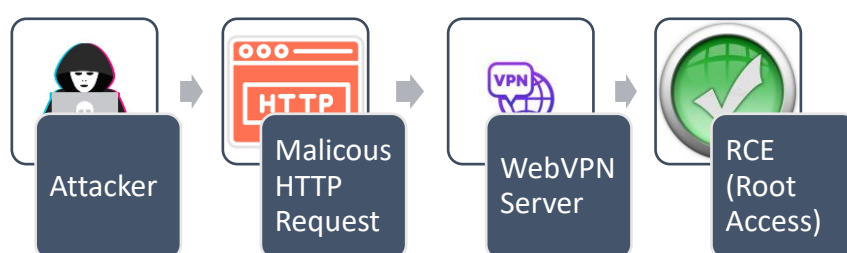


Figure 1: Exploitation Flow of Heap Buffer Overflow Vulnerability

2.6 Example Attacks

This was exploited in 2025 during the "ArcaneDoor" cyber espionage campaign which targeted legacy ASA 5500-X firewalls using two primary tools:

- **RayInitiator:** A boot kit that modifies GRUB bootloader to establish deep, long-term persistence [4].
- **LINE VIPER:** A stealthy, modular payload which executes commands, captures traffic, and hides logs using encrypted channels [4].

2.7 Impact of the Attacks

- Compromise the firewall by executing remote codes with root-level privileges.
- Ability to intercept internal credentials and allow seamless logins.
- Allows to perform information gathering of the target and network data exfiltration without triggering internal alarms.
- This can result in financial losses due to operational disruptions and recovery costs, leading to reputational damage and losing customer trust because of exposing sensitive data.

2.8 Mitigation Strategies

- Apply official software patches released by the vendor for devices operating with ASA and FTD operating systems.
- Increase hardware refresh cycles of the network devices to replace legacy devices such as ASA 5500-X series that lack hardware based secure boot technologies
- Perform full credential, password, and certificate resets across the affected network infrastructure assuming a total compromise.
- Perform IDS/IPS Monitoring actively for suspicious activities.
- Disable unused VPN services while restricting VPN exposure.

3 Vulnerability 2: CVE-2024-6387 - OpenSSH "regreSSHion" RCE

Vulnerability	CVE-2024-6387
Affected Entity	SSH protocol
Severity	High
Rating	8.1/10.0
Published Date	07/01/2024

3.1 Protocol Affected

The following vulnerability primarily affects the **OpenSSH server daemon (sshd)** running on glibc-based Linux systems [5]. This specifically targets the secure shell (SSH) protocol. Software versions include legacy OpenSSH releases earlier to 4.4p1, as well as modern versions such as 8.5p1 [6], [7].

3.2 Nature of Vulnerability & Severity

This vulnerability performs an unauthenticated Remote Code Execution (RCE), also known as "regreSSHion." It carries a **HIGH** severity **CVSS base score of 8.1 out of 10** [5], [6]. The flaw is conducted by a signal handler race condition, allowing remote attackers to obtain root-level privileges on the Linux operating System [7].

3.3 Component Affected

The background process **SIGALRM** signal handler within the sshd process is mainly affected by this vulnerability [5], [7]. SIGALRM is mainly responsible for managing timeout events during an event where the user attempts to log in but fails to complete the authentication process within the given timeframe by the system.

3.4 Reason for the Vulnerability to Exist

The reason this vulnerability exists is because of a code regression, which means that a software update indirectly reintroduced a vulnerability that was patched around two decades ago [6]. When a client connection exceeds the LoginGraceTime, which is by default 120 seconds, the SIGALRM handler executes asynchronously. The vulnerability exists because of this handler incorrectly calling functions that are not "async-signal-safe" such as *syslog()*, *malloc()* and *free()*, which would directly lead to heap memory corruption [5], [7].

3.5 Exploitation Methods

The following vulnerability can be exploited by initiating thousands of SSH connections without completing the authentication handshake [7]. The attacker successfully triggers an unsafe signal handler by precisely timing the expiration of *LoginGraceTime*. Furthermore, by using heap manipulation techniques, attackers force the system to execute a crafted payload, which would terminate the timed-out connection [7]. According to the reports, to achieve this, it requires overcoming Address Space Layout Randomization (ASLR) which requires over 10,000 attempts over several hours of continuous connections [6], [7].

3.6 Example Attacks

This vulnerability was discovered by the Qualys Threat Research Unit (TRU) in July 2024 [6]. Immediately after disclosing the vulnerability, it was discovered that many automated campaigns were being conducted by threat actors; it was estimated that around 14 million vulnerable OpenSSH servers were targeted [6], [8]. These threat actors used python-based proof of concept (PoC) scripts to target vulnerable 32-bit and 64-bit Linux architectures across enterprise environments [7], [8].

3.7 Impact of the Attacks

- Attackers can obtain root-level remote code execution on the server, leading to a total system compromise.
- Attackers will be successfully able to disable security measures implemented by organizations, such as firewalls and logging mechanisms.
- As SSH is highly trusted by systems, this would allow lateral movement within the network host, that would allow attackers to travel deeper into a compromised network.
- Successful exploitation would cause data exfiltration, granting attackers full visibility into databases, proprietary keys, and source codes stored within the host.

3.8 Mitigation Strategies

- The **Primary countermeasure** is to upgrade OpenSSH version to 9.8p1 or apply the patches provided by Linux vendor.
- **Implement access controls** by using VPNs, Zero Trust Network Access (ZTNA), and implement a strict firewall ACL list so that only trusted IPs can access the network.
- **Ensure not to directly expose an SSH server** to the public internet, as attackers may perform DoS attacks towards the network, making legitimate users unable to access the network.
- **Perform network segmentation** by separating critical servers in an isolated location to mitigate damage during a compromise.

4 Vulnerability 3: CVE-2023-20198 - Cisco IOS XE Web UI Privilege Escalation / RCE

Vulnerability	CVE-2023-20198
Affected Entities	Cisco routers and switches operate under IOS XE operating system
Severity	Critical
Rating	10.0/10.0
Published Date	10/16/2023

4.1 Device or Protocol Affected

This is a vulnerability of the Cisco routers and switches that operate under the IOS XE operating system and have the HTML/HTTPS Web User Interface (Web UI) enabled. Common ones include enterprise access, distribution and core devices including many Catalyst and ISR/ASR models including service provider and large organization deployments [9].

These devices can be frequently accessed via the internet to be remotely managed hence any Web UI vulnerability is especially hazardous.

4.2 Nature of Vulnerability & Severity

CVE 2023 20198 is a vulnerability of IOS XE Web UI **authentication bypass**. A network intruder who has not been authenticated can create a new user account on the computer with the level 15 privilege (full administrator). Together with a similar bug (CVE 2023 20273), the account could be utilized to conduct arbitrary operations on the device, providing effective **remote code execution (RCE)** [9], [10].

Cisco evaluated this problem as Critical with a **CVSS rating of 10.0** since:

- It requires no authentication.
- Exploitation is of low complexity, and it is remotely accessible.
- A successful attack allows full control over the device [9], [13].

4.3 Component Affected and Reason for the Vulnerability to Exist

The vulnerability is on the **HTTP Server / Web UI sub-component** of IOS XE. There is a lack of authentication and authorization checks within a certain REST-based API endpoint. The designed HTTP requests may go to the internal configuration functions which are only supposed to be accessed by logged-in administrators.

In other words, the Web UI:

- It is assumed that only authenticated users can access some backend functions.
- Thoroughly does not recheck the session or privilege level to process the request.

It is this absence of **access-control checks** combined with **reliance on user input** that is the genesis of the vulnerability [9].

4.4 Exploitation Methods and Example Attacks

Practically, it is easy to exploit. The steps followed by an average attacker would be:

1. Scanning: Internet-wide scanners can be used to identify IP addresses which expose Cisco IOS XE Web UI on TCP ports 80 or 443.
2. Exploit request: The vulnerable endpoint exploits allow the generation of a new local administrator account via silent HTTP POST requests made.
3. Admin access: Log in to the Web UI or the SSH using the account created by an attacker.
4. Additional compromise: Drop an evil implant or adjust the settings to stay alive and compromise deeper into the network [10], [13].

On October 2023, Cisco Talos and CISA announced that it was **exploited in the wild on a large-scale**. Thousands of devices were discovered to have suspicious accounts and implants written in Lua embedded into them that enabled remote access despite changing passwords [9], [10].

4.5 Impact of the Attacks

After being compromised, the router or switch has been turned into a slave to the attackers.

Technical impacts include:

- Complete configuration (routes, VLANs, ACLs, QoS.).
- Metadata capability to capture, reflect, or redirect network traffic (man-in-the-middle).
- Relaxation or deactivation of security control systems like ACL and the IPS features.

In terms of business and organization, the outcomes can be:

- Confidentiality and integrity of sensitive data is lost across the device.
- Horizontal movement to internal servers and user network.
- Loss of service and poor performance.
- The loss of reputation and the possible failure to abide by the data-protection rules [10].

4.6 Mitigation Strategies

The primary mitigation measure is to **upgrade all vulnerable IOS XE systems** to a fixed release in Cisco advisory [9]. Since vulnerability has been massively exploited, organizations are also supposed to presuppose compromise and research.

Recommended defenses:

- IP http IP server **Disable Web UI** (ip http server) where available, administer through SSH over separate management networks.
- **Limit access to management** ports with firewalls and ACLs to allow only trusted hosts of administration, or subnets of VPNs, to access management ports.
- Periodically check the local account of unknown users and delete suspected users.
- **Track logs and settings** of published indicators of compromise and abnormal HTTP requests by Cisco [9], [10], [13].
- Introduce a formal **patch-management and configuration-management** cycle of network infrastructure to have cases of similar issues solved promptly.

5 Vulnerability 4: CVE-2023-27997 - Fortinet FortiOS / FortiProxy SSL-VPN Heap Overflow (“Xortigate”)

Vulnerability	CVE-2023-27997
Affected Entity	Fortinet FortiOS
Severity	Critical
Rating	9.0/10.0
Published Date	06/13/2023

5.1 Device or Protocol Affected

CVE-2023-27997 impacts Fortinet **FortiGate** devices **firewall** systems and **FortiProxy** devices that utilize the FortiOS or FortiProxy with version numbers vulnerable to CSS-VPN and with it activated. These devices offer both remote access to employees and third parties and they are usually implemented directly on the internet perimeter [11].

A vulnerability here is devastatingly important since they end encrypted VPN connections and can be used in many cases to establish a single point of entry into the private networks.

5.2 Nature of Vulnerability & Severity

The problem is stack overflow of **heap-based buffer overflow** in the component of the SSL-VPN. During the TLS handshake, a remote attacker can relay spearheaded packets to overflow a heap buffer and obtain control over the execution flow. More importantly, the attack is **pre-authentication**, a valid VPN username or password is not required [11], [12].

Fortinet classified vulnerability as **Critical** (CVSS in the high -9 range) because:

- Internet accessibility.
- None of them had been authenticated.
- Risk of full system-level remote code execution (RCE) [11], [13].

5.3 Component Affected and Reason for the Vulnerability to Exist

The vulnerable code is on sslvpn **daemon** which parses the incoming ssl-vpn connections. In parsing some of the parameters, the daemon copy's data provided by attackers to a fixed-size heap buffer without attempting to correct overly long or malformed fields.

The fundamental issues are:

- **Weak bounds checking** on untrusted network data.
- Unsafe C-language memory functions were used.
- Lacking a protocol parsing logic speculators of fuzz-testing prior to release [11].

It is a well-known memory-safety bug, which gives an attacker the chance to overwrite the memory around and, in the long run, take over the process control flow.

5.4 Exploitation Methods and Example Attacks

An actual sequence of exploitations would appear as follows:

- **Discovery:** The attacker searches the internet using FortiGate or FortiProxy system with a discovered exposed SSL-VPN, typically on TCP 443.
- **Triggering the overflow:** TLS packets that are specially created are sent to the SSL-VPN server and the overflow is triggered in the sslvpn process.
- **Code execution:** Payloads are carefully crafted to replace the address of a function or a return address so that the shellcode under the attacker control will be executed as root privileges [11].

Following the public disclosure in mid-2023, CISA and several security vendors documented that they were being exploited on a mass scale. The compromised devices were also seen to be operating web shells, reverse shells to the infrastructure of the attackers, and were used as a point of entry to ransomware and other targeted attacks [12], [13].

5.5 Impact of the Attacks

Since FortiGate and FortiProxy appliances are at the edge of the network, one successful exploit can destroy an entire organization.

Key technical impacts:

- Full access to the firewall or proxy set up.
- VPN credentials theft and possible decryption or traffic inspection of VPN.
- Development of secret administrative accounts or malware.
- Attack internal servers and workstations by pivoting on the device.

Examples of business effects are:

- Interruption of remote-access services to employees and affiliates.
- Answers to sensitive or regulated data have been lost.
- Losses, costs of incident-response and recovery.
- Loss of reputation of the organization and potential legal or regulatory implications [12].

5.6 Mitigation Strategies

Patched versions of FortiOS and FortiProxy were released by Fortinet hence the most important step is to upgrade all the affected appliances [11]. Due to the presence of exploitation in the wild, one should verify the devices to be free of compromise.

Suggested defenses:

- **Reboot and patch** all FortiGate/FortiProxy systems which make access to the SSL-VPN.
- In the case of patching delay, **restrict access** by configuring VPN access to trusted IP addresses or locating the VPN behind some other access control.
- **Turn on multi-factor authentication (MFA)** on any VPN user to ensure the worth of any stolen credentials is reduced to minimum.
- Review logs for:
 - Created or updated administrator accounts,
 - Unusual VPN login patterns,
 - Unforeseen connections going out of firewall itself [11], [12].
- Keep a current list of **assets and patch-management** policies of all perimeter devices and perform frequent vulnerability scans to identify obsolete VPN services [13].

6 Vulnerability 5: CVE-2025-0282 – Ivanti Connect Secure Stack-Based Buffer Overflow

Vulnerability	CVE-2025-0282
Affected Entities	Ivanti Connect Secure (ICS)
Severity	Critical
Rating	9.0/10.0
Published Date	01/08/2025

6.1 Device or Protocol Affected

CVE-2025-0282 vulnerability affected the **Ivanti Connect Secure (ICS)** SSL VPN appliance, along with **Policy Secure** and **ZTA gateway** products. These devices are highly vulnerable because of directly accessible from the internet, any **unauthenticated remote code execution** (RCE). The affected versions are Ivanti Connect Secure prior to 22.7R2.5, Policy Secure prior to 22.7R2, and ZTA gateways prior to 22.7R1.3. [14][18]

6.2 Nature of Vulnerability & Severity

This vulnerability type is **stack-based buffer overflow** that affects the web-facing component of the ICS, Policy Secure and ZTA gateway appliance. Without requiring physical or logical access an attacker can gain unauthorized remote access to overflow the fixed-length stack buffer by sending a crafted request and achieving arbitrary code execution on the device without any credentials. This vulnerability carries a **CVSS score of 9.0**, reflecting the highest severity of an unauthenticated RCE vulnerability. [14][18]

6.3 Component Affected

The **Ivanti Firewall Traversal (IFT) protocol** is affected to the web process (/home/bin/web) that is handle client capabilities. The remote clients reach through outward-facing HTTP interface to establish the VPN sessions; this causes the path to be vulnerable to remote code execution. The threat actor UNC5221 leveraged multiple custom malware families targeted on this device, including ZIPLINE, THINSPOOL, LIGHTWIRE, and WARPWIRE, along with the PySoxy tunneler and BusyBox utilities for post-exploitation activity. [14][18]

6.4 Reason for the Vulnerability to Exist

The root cause is a bounds-checking vulnerability in the Ivanti web process **that allows crafted client capabilities value to overflow a 256-byte stack buffer**. The code improperly uses *strcpy()* with the source length rather than the destination buffer size. If the client capabilities value exceeded the 256-bytes causes an out-of-bounds write that can corrupt return address and function pointers.

6.5 Exploitation Methods

- **Unauthenticated remote exploitation:** Sending crafted HTTP/IFT request with client capabilities field exceeding 256 bytes overflows the stack buffer and enables remote code execution in the web process.
- **Version enumeration as reconnaissance:** Attackers first probe endpoints such as `/dana-cached/hc/hc_launcher` to determine the software version before launching the exploitation.
- **Chained multi-stage exploitation:** The initial overflow is used to execute a `setuid` ELF stager, deploy the PHASEJAM dropper, install Perl web shells, and establish persistent backdoors.
- **Reconnaissance:** Recent campaigns have demonstrated coordinated scanning using both concentrated infrastructure and distributed botnet approaches across 6,000+ Ips targeting vulnerable instances. [16][14]

6.6 Example Attacks

- **Reconnaissance:** Attacker scans for vulnerable Ivanti Connect Secure instances via requests to `/dana-na/auth/url_default/welcome.cgi`.
- **Exploitation:** Send malicious IFT requests with a crafted client Capabilities value triggering the buffer overflow.
- **Persistence Installation:** Deploys web shells in `/home/webserver/htdocs/dana-na/auth/` directories.
- **Defense Evasion:** Executes commands including `setenforce 0` (disable SELinux), iptables rules to block syslog output.
- **Backdoor Installation:** Install SPAWN, DRYHOOK, PHASEJAM persistent components are deployed for long-term access. [16]

6.7 Impact of the Attacks

- **Complete device compromise:** Remote attackers gain root-level code execution on the appliance.
- **Persistent backdoor access:** Attackers survive long-term access even after reboots.
- **Credential theft:** Stored session cookies, API keys, certificates, and Active Directory credentials harvesting from the LMDB cache.
- **Configuration exfiltration:** Exfiltrate archived or staged sensitive running configurations.
- **Network Perimeter Breach:** Compromise VPN appliance leads to bypass all of perimeter security controls. [19][21]

6.8 Mitigation Strategies

- **Immediate Patching:** Upgrade ICS to 22.7R2.5, Policy Secure to 22.7R2, and ZTA gateways to 22.7R1.3 and apply necessary patches to identify vulnerabilities.
- **Run Integrity Checker Tool (ICT):** Execute internal and external ICT scans to identify security weaknesses in the system, if threat actions determine compromise report to the CISA and Ivanti immediately to start investigation.
- **Credential Revocation:** Revoke and reissue exposed certificates, keys, and passwords, API tokens.[20]

7 Vulnerability 6: CVE-2024-3400 – Palo Alto Networks PAN-OS Global Protect Command Injection

Vulnerability	CVE-2024-3400
Affected Entity	Palo Alto PAN-OS
Severity	Critical
Rating	10.0/10.0
Published Date	04/12/2024

7.1 Device or Protocol Affected

CVE-2024-3400 vulnerability affects **Palo Alto Network firewall running PAN-OS software** with the GlobalProtect gateway or portal feature enables. PAN-OS software is the operating system powering Palo Alto's NGFW range, and GlobalProtect is the integrated SSL VPN component. For enterprises network security control deployed by these firewalls protect from compromising in highest possible severity. PAN-OS 10.9-H1, 10.2.8-H3, and 11.0.4-h1, 11.1.2-h3 are the affected PAN-OS versions. [15][17]

7.2 Nature of Vulnerability & Severity

The vulnerability type is **command injection vulnerability** that combined with improper input validation in the GlobalProtect feature to allow arbitrary file creation leading to remote code execution via HTTPS. Which can execute operation system commands with root privileges. The **CVSS score is 10.0** reflecting full impact across confidentiality, integrity, and availability. [15][17]

7.3 Component Affected

The vulnerability exactly affected components of **PAN-OSs on GlobalProtects gateway and portal**, especially the session handling and processing code within the **GPSVC gateway and portal interfaces**. These components handle SSL VPN connections and user authentication request received on externally facing management. The flaws exist in GPSVC handles session data that passed user input into unsensitized file creation operations or remote command execution paths. [15]

7.4 Reason for the Vulnerability to Exist

The root cause is a command injection vulnerability resulting from **failure to sanitize user input properly**. The GlobalProtect service processes session data does not validate session input before using it in system commands. An attacker injects arbitrary OS commands that execute with root privileges. This vulnerability can be triggered through crafted requests that lead to arbitrary filenames, and creation in sensitive filesystem location. [15]

7.5 Exploitation Methods

Exploitation is divided into four parts:

1. **Probing:** An attacker accesses the client network but cannot attempt to successful exploitation.
2. **Test:** A 0-byte file has been created successfully and is resident on the firewall with no indication of known unauthorized command execution.
3. **Potential Exfiltration:** Sensitive file that contain firewall configuration and credentials has been copied to location via a web request. Observed commonly copied file and credentials is `running_config.xml`.
4. **Interactive Access:** There are signs of full shell-based backdoor deployment and introduction of code, downloading file or running commands. [15]

7.6 Example Attacks

- **Initial Exploitation:** An attacker sends crafted requests to vulnerable GlobalProtect interface and creates arbitrary files on the firewall.
- **Backdoor Deployment:** Threat actor initially installs a python based backdoor, which is "UPSTYLE".
- **Command Execution:** After failing to install UPSTYLE, the threat actor runs commands on the firewall. The commands copying configuration files to the web application folder and exfiltrating them via HTTP requests.
- **Lateral Movement:** Attackers decide to install additional tools because of unsuccessful to install UPSTYLE. The threat actors install a cron job backdoor to carry out post-exploitation activities. [15]

7.7 Impact of the Attacks

- **Root-level firewall compromise:** Attackers gain complete administrative control over the organization's firewall with root privileges.
- **Configuration and credential exposure:** Running configuration files like `running_config.xml` and exfiltrate firewall rules, VPN credentials, certificates.
- **Backdoor persistence:** Install python-based UPSTYLE backdoors provide sustained access.
- **Security control bypass:** Attacker bypass security control and the firewall itself became a threat vector. [15]

7.8 Mitigation Strategies

- **Immediate Patching:** Upgrade to a fixed PAN-OS version (10.2.9-h1, 10.2.8-h3, 11.0.4-h1, 11.1.2-h3)
- **Threat prevention subscription:** Block attacks using threat IDs 95187, 95189, and 95191. As an interim protective measure, vulnerability protection must be applied to GlobalProtect interfaces.
- **Credential revocation:** Credentials and certificates, VPN username and passwords that may have been exposed through `running_config.xml` exfiltration.
- **Network segmentations and access control:** Restrict internet access to the GlobalProtect services interfaces and portals. And placing application-layer proxy or WAF where operationally feasible. [15]

8 Vulnerability 7: CVE-2023-44487 – HTTP/2 Rapid Reset Attack

Vulnerability	CVE-2023-44487
Affected Entity	HTTP/2
Severity	High
Rating	7.5/10.0
Published Date	10/10/2023

8.1 Device or Protocol Affected

CVE-2023-44487 impacts the **HTTP/2 protocol** which serves as a fundamental component of contemporary web communication systems that seek to enhance both operational speed and network performance [23]. HTTP/2 exists in numerous web servers and cloud services, and content delivery networks which include Google Cloud and Amazon Web Services and Cloudflare [22]. The vulnerability affects all internet-facing systems because of its widespread use.

8.2 Nature of Vulnerability & Severity

The vulnerability **enables a Denial-of-Service (DoS) attack** which functions as a large-scale Distributed Denial-of-Service (DDoS) attack [22]. The system has been rated as **HIGH severity** because attackers can use small network traffic to overpower even well-equipped servers [23]. The attack exploits a design weakness in HTTP/2 rather than a simple coding error [24].

8.3 Component Affected

The vulnerability exists because HTTP/2 stream management fails to handle **RST_STREAM** frame requests which request cancellation of streams. The server requires resources to process requests, but it cannot handle stream cancellations which occur at high speed [24].

8.4 Reason for the Vulnerability to Exist

The creators of HTTP/2 designed the protocol to enable users to transmit multiple simultaneous requests through a single network connection which would enhance efficiency [22]. The system does not limit request cancellation and creation to appropriate speeds [23]. This creates a loophole where attackers can repeatedly open and cancel streams which forces the server to waste resources through processing incomplete requests. The system vulnerability occurs because there is no effective rate control and resource management [22].

8.5 Exploitation Methods

The attacker establishes a connection to the target server and sends multiple HTTP/2 requests to exploit this vulnerability [23]. The attacker uses the RST_STREAM frame to cancel each request immediately after sending it [24]. The server experiences ongoing resource allocation and release activities because the process operates at a high speed. Over time this behavior results in total resource depletion which causes the system to either malfunction or become extremely slow.

8.6 Example Attacks

This vulnerability enabled two of the biggest DDoS attacks ever recorded which achieved attack rates above 400 million requests per second in 2023. Major companies such as Google, Cloudflare, and AWS reported being targeted [22]. The attacks proved that attackers could use this method to compromise even the most secure systems

8.7 Impact of the Attacks

The impact of this vulnerability is significant and includes:

- Server downtime and service unavailability.
- Disruption of websites and online services.
- Financial losses due to business interruptions.
- Reduced user trust and reputation damage.
- Increased operational costs for mitigation.

8.8 Mitigation Strategies

To reduce the risk associated with this vulnerability, organizations should:

- Vendors must provide security patches and updates which organizations should apply.
- Rate limiting needs to be implemented to control excessive request access.
- Servers need configuration to restrict simultaneous streaming connections.
- Web Application Firewalls need deployment to block harmful network traffic.
- Organizations should track their network activity to identify any strange request behavior.
- Organizations should implement load balancing together with traffic distribution methods.

9 Vulnerability 8: CVE-2023-4966 – Citrix NetScaler “Citrix Bleed”

Vulnerability	CVE-2023-4966
Affected Entity	Citrix NetScaler
Severity	Critical
Rating	9.4/10.0
Published Date	10/10/2023

9.1 Device or Protocol Affected

CVE-2023-4966 impacts **Citrix NetScaler ADC and Gateway**, which organizations use to deliver secure remote access, VPN services and application delivery. The security flaw presents major risks because organizations use these devices throughout their enterprise networks [25].

9.2 Nature of Vulnerability & Severity

The system contains a vulnerability that allows sensitive information to be disclosed to unauthorized users. The system has **CRITICAL** security rating because attackers can obtain sensitive information through session tokens without needing to authenticate themselves. Unauthorized users can access protected systems because they no longer need to provide login credentials [25], [26].

9.3 Component Affected

The security weakness exists within **NetScaler session handling and memory management system**. The issue specifically impacts how the system manages user interactions and handles session data during processing [25].

9.4 Reason for the Vulnerability to Exist

The security gap exists because the system cannot properly manage user input or memory usage, which leads to dangerous data exposure. The system demonstrates a security flaw because it fails to separate different memory areas, which attackers can use to access confidential data. This problem occurs because systems fail to verify data boundaries and handle memory in an unsafe manner [26].

9.5 Exploitation Methods

An attacker can exploit this vulnerability by sending specially crafted requests to a vulnerable NetScaler device. The system processes the requests by returning memory sections which hold confidential information. The attacker can extract session tokens which will allow him to impersonate actual users while avoiding authentication controls [25].

9.6 Example Attacks

The vulnerability became a target for actual attacks against business networks during 2023. The attackers used this method to take control of current VPN connections which allowed them to access protected internal networks. Multiple organizations experienced security breaches because attackers gained unauthorized system access through this security weakness [25].

9.7 Impact of the Attacks

The impact of this vulnerability is severe and includes:

- Unauthorized individuals to access protected internal systems.
- Enables attackers to hijack user sessions without needing their login credentials.
- Data breaches which result in the distribution of confidential business information.
- Allow attackers to move through different parts of the protected network.
- Total system control by threat actors, leading to severe financial and reputational damage.

9.8 Mitigation Strategies

Organizations can mitigate this vulnerability by:

- Applying the latest Citrix security patches immediately.
- Terminating all active sessions after patching.
- Enabling Multi-Factor Authentication (MFA).
- Monitoring logs for suspicious activity.
- Restricting external access to NetScaler devices.
- Implementing network segmentation to limit exposure.

10 Conclusion

In conclusion, vulnerabilities described in this report present security risks related to modern network devices and protocols. From weaknesses related to memory including buffer overflows to logic related issues such as authentication bypasses and race conditions, these successfully manage to outline how errors related to implementation and weaknesses in design are exploited by attackers.

The real-world examples suggest that the threat actors mostly target these weaknesses to gain unauthorized access and move laterally within networks. This shows how important it is to maintain a reliable security approach rather than entirely relying on reactive countermeasures.

The analysis suggests that to successfully reduce these risks organizations must focus on areas such as patch management, restrict unnecessary exposure of network services and implement strong access control mechanisms while continuously monitoring the network. Moreover, organizations can reduce impact of these risks by following best security practices such as network segmentation and zero trust principles.

Finally, with understanding of these vulnerabilities and exploitation techniques it is essential to build a strong network infrastructure and improve overall cybersecurity posture of organizations.

11 Contribution

Member Name	Contribution
Hansaja R.D	1. Vulnerability 1: CVE-2025-20333 - Cisco ASA and FTD WebVPN Heap Buffer Overflow 2. Vulnerability 2: CVE-2024-6387 - OpenSSH "regreSSHion" RCE
Danamjan V	1. Vulnerability 3: CVE 2023 20198 - Cisco IOS XE Web UI Privilege Escalation / RCE 2. Vulnerability 4: CVE 2023 27997 - Fortinet FortiOS / FortiProxy SSL VPN Heap Overflow ("Xortigate")
Herath H.M.B.D	1. Vulnerability 5: CVE-2025-0282 – Ivanti Connect Secure Stack-Based Buffer Overflow 2. Vulnerability 6: CVE-2024-3400 – Palo Alto Networks PAN-OS Global Protect Command Injection
Sathursha.R	1. Vulnerability 7: CVE-2023-44487 – HTTP/2 Rapid Reset Attack 2. Vulnerability 8: CVE-2023-4966 – Citrix NetScaler "Citrix Bleed"

12 References

- [1] National Institute of Standards and Technology, "CVE-2025-20333 Detail," September 25, 2025. [Online]. Available: <https://nvd.nist.gov/vuln/detail/cve-2025-20333>
- [2] Cisco Systems, Inc., "Cisco Secure Firewall Adaptive Security Appliance Software and Secure Firewall Threat Defense Software VPN Web Server Remote Code Execution Vulnerability," September 25, 2025. [Online]. Available: <https://sec.cloudapps.cisco.com/security/center/content/CiscoSecurityAdvisory/cisco-sa-asaftd-webvpn-z5xP8EUB>
- [3] R. Emmons, "CVE-2025-20333, CVE-2025-20362, CVE-2025-20363 - Multiple critical vulnerabilities affecting Cisco products," *Rapid7 Blog*, September 26, 2025. [Online]. Available: <https://www.rapid7.com/blog/post/etr-cve-2025-20333-cve-2025-20362-cve-2025-20363-multiple-critical-vulnerabilities-affecting-cisco-products/>
- [4] A. Singh, D. Desai, J. P. Nair, and R. Hegde, "Cisco Firewall and VPN Zero Day Attacks: CVE-2025-20333 and CVE-2025-20362," *Zscaler Blog*, September 26, 2025. [Online]. Available: <https://www.zscaler.com/blogs/security-research/cisco-firewall-and-vpn-zero-day-attacks-cve-2025-20333-and-cve-2025-20362>
- [5] National Institute of Standards and Technology (NIST), "CVE-2024-6387 Detail," *National Vulnerability Database*, July 01, 2024. [Online]. Available: <https://nvd.nist.gov/vuln/detail/CVE-2024-6387>
- [6] Bharat Jogi, "Remote Unauthenticated Code Execution Vulnerability in OpenSSH Server (regreSSHion)" *Qualys Security Blog*, Jul. 22, 2024. [Online]. Available: <https://blog.qualys.com/vulnerabilities-threat-research/2024/07/01/regresshion-remote-unauthenticated-code-execution-vulnerability-in-openssh-server>
- [7] Datadog Security Labs, "RegreSSHion vulnerability CVE-2024-6387: Overview, detection, and remediation," *Datadog Blog*, Jul. 01, 2024. [Online]. Available: <https://securitylabs.datadoghq.com/articles/regresshion-vulnerability-cve-2024-6387-overview-detection-and-remediation/>
- [8] Censys, "regreSSHion RCE Vulnerability in OpenSSH Server," *Censys Advisories*, Jul. 02, 2024. [Online]. Available: <https://censys.com/advisory/cve-2024-6387>
- [9] "CVE - CVE-2023-20198," Mitre.org, 2023. <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2023-20198>

[10] C. and I. S. A. CISA), "Threat Actors Exploit Cisco IOS XE Software Web UI Vulnerability CVE 2023 20198," Cisa. <https://www.cisa.gov/known-exploited-vulnerabilities-catalog> (accessed Mar. 30, 2026).

[11] "FortiGuard," *FortiGuard*, Mar. 30, 2023. <https://www.fortiguard.com/psirt/FG-IR-23-097> (accessed Mar. 30, 2026).

[12] Cybersecurity and Infrastructure Security Agency, "Known Exploited Vulnerabilities Catalog | CISA," *www.cisa.gov*, 2023. <https://www.cisa.gov/known-exploited-vulnerabilities-catalog> (accessed Mar. 30, 2026).

[13] NIST, "NVD - CVE-2023-20198," *nvd.nist.gov*, 2023. <https://nvd.nist.gov/vuln/detail/CVE-2023-20198>

[14] "Ivanti VPN Vulnerability: Mitigation Strategies, Incident Response, and Defense"
[<https://www.paloaltonetworks.com/cyberpedia/ivanti-VPN-vulnerability-what-you-need-to-know#:~:text=Chinese%20state%2Dponsored%20hackers%20have,able%20to%20apply%20a%20patch>]

[15] "Operation MidnightEclipse, Post-Exploitation Activity Related to CVE-2024-3400"
[<https://unit42.paloaltonetworks.com/cve-2024-3400/>]

[16] "Ivanti Connect Secure VPN Targeted in New Zero-Day Exploitation"
[<https://cloud.google.com/blog/topics/threat-intelligence/ivanti-connect-secure-vpn-zero-day>]

[17] "Palo Alto Networks PAN-OS Global Protect Command Injection (CVE-2024-3400)"
[<https://www.cve.org/CVERecord?id=CVE-2024-3400>]

[18] "Ivanti Connect Secure Stack-Based Buffer Overflow (CVE-2025-0282)"
[<https://www.cve.org/CVERecord?id=CVE-2025-0282>]

[19] "Security Advisory Ivanti Connect Secure, Policy Secure & ZTA Gateways (CVE-2025-0282, CVE-2025-0283)"
[<https://forums.ivanti.com/s/article/Security-Advisory-Ivanti-Connect-Secure-Policy-Secure-ZTA-Gateways-CVE-2025-0282-CVE-2025-0283>]

[20] "CISA Mitigation Instructions for CVE-2025-0282 [<https://www.cisa.gov/cisa-mitigation-instructions-cve-2025-0282>]

[21] "John Wolfram, Josh Murchie, Matt Lin, Daniel Ainsworth, Robert Wallace, Dimiter Andonov, Dhanesh Kizhakkinan, Jacob Thompson Ivanti: Connect Secure VPN Targeted in New Zero-Day Exploitation"
[<https://cloud.google.com/blog/topics/threat-intelligence/ivanti-connect-secure-vpn-zero-day>]

[22] Cisco Systems, Inc., "Cisco Security Advisory: HTTP/2 Rapid Reset Attack Affecting Cisco Products," Advisory ID: cisco-sa-http2-reset-d8Kf32vZ, Oct. 16, 2023. [Online]. Available: <https://sec.cloudapps.cisco.com/security/center/content/CiscoSecurityAdvisory/cisco-sa-http2-reset-d8Kf32vZ>

[23] National Institute of Standards and Technology (NIST), "CVE-2023-44487 Detail," National Vulnerability Database, Oct. 10, 2023. [Online]. Available: <https://nvd.nist.gov/vuln/detail/CVE-2023-44487>

[24] Red Hat, "CVE-2023-44487," Red Hat Customer Portal, Oct. 10, 2023. [Online]. Available: <https://access.redhat.com/security/cve/cve-2023-44487>

[25] Rapid7, "CVE-2023-4966: Exploitation of Citrix NetScaler Information Disclosure Vulnerability," *Rapid7 Blog*, Oct. 25, 2023. Available <https://www.rapid7.com/blog/post/2023/10/25/etr-cve-2023-4966-exploitation-of-citrix-netscaler-information-disclosure-vulnerability/>

[26] National Institute of Standards and Technology (NIST), "CVE-2023-4966 Detail," *National Vulnerability Database*, Oct. 10, 2023. [Online]. Available: <https://nvd.nist.gov/vuln/detail/CVE-2023-4966>